

ACTIVITY PACK

Activity 4 - Evidence-Based Rogue Agent Incident Review

Complete learner scenario, practice and security checklist

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Readme

Activity 4 - Evidence-Based Rogue Agent Incident Review

Course: AI Security for Autonomous AI Agents **Course Code:** TGS-2025060473 | **TSC:** ICT-INT-0052-1.1 **Block:** Day 2 - Autonomous Agent Security

At a glance

Duration	60 minutes
Format	Small groups of 3 - 4, plenary debrief
Type	Evidence-based review: verified cases plus one reported security-research campaign
Learning Outcome	LO3
K/A statements assessed	K5

Purpose

Learners review EchoLeak, the Amazon Q Developer extension supply-chain event, the Replit application-database incident, and the reported ClawHavoc malicious-skill campaign. They distinguish evidence status, reconstruct source-to-sink chains, and identify the earliest deterministic control that could break each chain.

Files in this folder

File	Audience	Use
SCENARIO.md	Learner	The case study narrative, artefacts and data
DISCUSSION-QUESTIONS.md	Learner	The five questions to work through in groups
SKILL-PLUGIN-RISK-REVIEW.md	Learner	Supply-chain review exercise for skills, plugins and MCP servers
SECURITY-CHECKLIST.md	Learner	Autonomous-agent containment checklist
Activity-4-*.pdf	Learner	Printable full learner pack including supply-chain review and checklist

How to run it

1. **Set up (5 min).** Form groups of 3 - 4. Issue SCENARIO.md and DISCUSSION-QUESTIONS.md. Trainer debrief notes are supplied separately and are not stored in the learner-facing Activities folder.
2. **Group work (45 minutes).** Groups work the five questions in order. Circulate; the questions are designed to be argued, not looked up.
3. **Presentation (5 minutes).** Each group presents its answer to one nominated question.
4. **Debrief (5 minutes).** Use the separate trainer notes to draw out the teaching points and correct recurring misconceptions.

Learner workflow

1. Create an evidence card for EchoLeak, Amazon Q, Replit and ClawHavoc: source, publication date, evidence class and exact supported claim.
2. For every case, separate normal capability, vulnerability or control failure, and observed or possible impact.
3. Map untrusted source, interpretation mechanism, identity or permission, privileged sink and effect.
4. Record what the source does **not** establish; preserve the Amazon Q, Replit and ClawHavoc cautions.
5. Complete SKILL-PLUGIN-RISK-REVIEW.md for one skill, plugin or MCP server, including provenance, version, update channel, requested capabilities and bundled code.

6. Choose one preventive and one detective or recovery control at the earliest feasible chain point.
7. Define any required approval screen: exact action, target, data, scope, destination, reversibility and evidence shown.
8. Present the reconstruction without converting a vulnerability, demonstration or reported campaign into an unsupported production-breach claim.

Required evidence

- Four evidence cards, each with a dated source and CASE-V or CASE-R label.
- Four source-to-sink chains with supported and unsupported claims separated.
- One skill/plugin/MCP supply-chain review with an allow, conditional-allow or deny decision.
- Preventive plus detective or recovery controls, with owners, test evidence and residual risk.

Acceptance criteria

The submission passes when all four evidence classes and source cautions are preserved; Amazon Q is stated as not executed, Replit as restored with no data loss, and ClawHavoc figures retain their dated methodology limits; and the supply-chain review ends in an explicit gate decision.

The slide deck remains concept-led. These learner procedures are also reproduced in the Learner Guide.

Alignment

Every question in DISCUSSION-QUESTIONS.md is tagged with the K or A statement it evidences. This activity contributes to **LO3** and is assessed through the Written Assessment (SAQ).

This material belongs to Tertiary Infotech Pte Ltd (UEN: 20120096W). All Rights Reserved.

Scenario

Activity 4 - Evidence-Based Rogue Agent Incident Review

Scope and evidence status

Course: AI Security for Autonomous AI Agents (TGS-2025060473)

Duration: 60 minutes | **Format:** Small groups of 3-4

Type: Documented cases and one reported security-research campaign

This activity uses source-faithful summaries. It distinguishes a verified vulnerability, a confirmed software supply-chain event, a first-party product incident, and a security-research campaign. It does not treat a demonstration, evaluation, or reported campaign as proof that every deployment was compromised.

Use this analysis grammar for every case:

untrusted source -> mechanism -> privileged sink or action -> impact -> deterministic control -> residual risk and evidence

Case A - EchoLeak / CVE-2025-32711

Evidence label: CASE-V - verified vulnerability, fixed by Microsoft

System: Microsoft 365 Copilot

Primary anchors: Microsoft vendor advisory and NVD record for CVE-2025-32711

Microsoft's CVE description states that AI command injection in Microsoft 365 Copilot could allow an unauthorised attacker to disclose information over a network. Microsoft's later security explanation describes EchoLeak as a fixed, multi-stage cross-prompt-injection technique that, under certain conditions, could exfiltrate limited data already accessible to the victim.

Evidence-safe chain

1. An attacker controls content that can enter the user's organisational context.
2. The content carries instructions intended for the model rather than the human reader.
3. The model can combine that content with information available under the user's existing access.
4. An external rendering or network path becomes a possible disclosure sink.

What this case supports

- Indirect prompt injection can be delivered through ordinary business content.
- Existing user permissions can increase the value of a successful injection.
- Input filtering alone is not a complete boundary; source-to-sink and outbound controls matter.

What this case does not support

- It does not establish that every Microsoft 365 tenant was compromised.
- It does not establish a count of affected customers.
- A vulnerability is not the same thing as confirmed malicious exploitation.

Sources:

- <https://nvd.nist.gov/vuln/detail/CVE-2025-32711>
- <https://www.microsoft.com/en-us/security/security-insider/emerging-trends/ai-application-security-considerations-for-organizations>

Case B - Amazon Q Developer extension v1.84.0 / CVE-2025-8217

Evidence label: CASE-V - confirmed by AWS Security Bulletin AWS-2025-015

System: Amazon Q Developer extension for Visual Studio Code

AWS states that an inappropriately scoped GitHub token allowed a threat actor to commit malicious code that was automatically included in extension version 1.84.0. AWS also states that the code failed to execute because it contained a syntax error. AWS revoked and replaced credentials, withdrew version 1.84.0, and released version 1.85.0.

Evidence-safe chain

1. A build or repository credential had more authority than necessary.
2. A threat actor used that authority to alter source used by an automated release path.
3. The resulting extension version was distributed.
4. The malicious code did not execute because of its syntax error.

Control lessons

- Use narrowly scoped, short-lived CI and release identities.
- Protect release branches and require independent review for release changes.
- Pin, sign, inventory, stage, and rapidly revoke software artifacts.
- Treat extensions used by coding agents as part of the executable supply chain.

Source: <https://aws.amazon.com/security/security-bulletins/AWS-2025-015/>

Case C - Replit Agent and an application database

Evidence label: CASE-V - first-party Replit account

System: Replit Agent

Replit states that its Agent deleted data from Jason Lemkin's application database before Replit's development and production databases were separated by default. Replit states that the database was fully restored and no data was lost. Its response emphasised stronger development/production separation, checkpoints, rollback, and modes that let a user plan without authorising execution.

Evidence-safe chain

1. The agent had access to an environment containing important data.
2. A generated plan selected a destructive operation.
3. No deterministic environment boundary stopped the operation before execution.
4. Recovery controls restored the data after the event.

Control lessons

- Separate development and production by construction.
- Deny production writes and deletion to development agents.
- Require an exact, one-time approval for exceptional irreversible actions.
- Test checkpoints and rollback, while remembering that recovery is not prevention.

Source: <https://replit.com/blog/doubling-down-on-our-commitment-to-secure-vibe-coding>

Case D - Reported malicious skills in the ClawHub ecosystem

Evidence label: CASE-R - named security-research campaign, not a platform-wide prevalence rate

System: OpenClaw skill ecosystem / ClawHub

Koi Security reported that its February 2026 audit identified 341 malicious skills among 2,857 skills examined at that time, with 335 linked to one campaign it called ClawHavoc. Use the numbers only with that date, denominator, and methodology. Do not generalise the ratio to the current registry or to every agent marketplace.

The broader security lesson is independent of the reported ratio: a skill may contain instructions, scripts, dependencies, tool definitions, and setup steps that execute with the agent's delegated authority. Installation therefore changes the attack surface and must be governed as a privileged change event.

Control lessons

- Verify publisher identity, repository history, and ownership changes.
- Pin the exact version or commit and record a checksum or signature where available.
- Review instructions, scripts, dependencies, tool schemas, requested credentials, and egress.
- Test in an isolated non-production environment with no ambient secrets.
- Require human approval for installation, update, and material permission changes.
- Maintain inventory, monitoring, rollback, and rapid revocation.

Sources:

- <https://www.koi.ai/blog/clawhavoc-341-malicious-clawedbot-skills-found-by-the-bot-they-were-targeting>
- <https://docs.openclaw.ai/gateway/security>

Your role

You are the post-incident review board for a Singapore organisation that uses a hosted GenAI assistant, a coding agent, and a self-hosted agent gateway. Your task is to decide which control would have broken each chain earliest, what evidence proves the control works, and which risks remain after the control is applied.

Do not rank products as safe or unsafe. Analyse the deployment boundary, data reach, identity, tools, code execution, network, memory, extension supply chain, approval policy, logging, and recoverability.

Discussion Questions

Activity 4 - Discussion Questions

Evidence-Based Rogue Agent Incident Review

Work through all five questions. Keep each fact tied to the case source and preserve the evidence label: CASE-V or CASE-R.

Q1 - Reconstruct a source-to-sink chain (K5)

Choose EchoLeak or the Amazon Q extension event. Map:

- untrusted source;
- mechanism;
- identity or permission used;
- privileged sink or action;
- observed or possible impact;
- earliest deterministic control;
- residual risk and required evidence.

Q2 - Separate capability, vulnerability, and impact (K5)

For all four cases, identify which statements describe a normal capability, which describe a vulnerability or control failure, and which describe an impact. Explain why code execution, network access, or persistent memory is not automatically a vulnerability.

Q3 - Distinguish evidence classes (K5)

Explain why:

- EchoLeak may be called a verified vulnerability without claiming every customer was attacked;
- the Amazon Q event must state that the malicious code did not execute;
- the Replit event must state that the data was restored and no data was lost;
- the ClawHavoc figures cannot be presented as today's marketplace prevalence.

Q4 - Break each chain at the earliest point (K5)

For every case, choose one preventive control and one detective or recovery control. State the owner, implementation point, test evidence, operational cost, and expected residual risk.

Q5 - Set your organisation's authority boundary (K5)

Classify these actions as **agent alone**, **human approval required**, or **prohibited**:

- read a non-sensitive repository;
- install or update a community skill;
- access a long-lived production token;
- send data to a new internet destination;
- write to production;
- delete a production resource;
- change access-control roles;
- create a scheduled background task.

For every action that requires approval, specify what the reviewer must see and why a system prompt saying "ask before acting" is not equivalent to a deterministic policy gate.

Skill Plugin Risk Review

Activity 4 - Skill, Plugin and MCP Supply-Chain Review

Assume an autonomous coding agent recommends a community skill called `secure-cloud-audit`, delivered with a `SKILL.md`, two shell scripts and an MCP server package. The marketplace page claims it can "auto-remediate every cloud finding" and asks for cloud-admin credentials.

Evidence request

Area	Questions	Evidence
Provenance	Who owns and maintains it? Is the name a near match? Has ownership changed?	Publisher identity, repository history, licence
Integrity	What exact content will run? Can the release change after review?	Pinned commit/version, checksum/signature, unpacked source
Capabilities	Which tools, files, commands, hosts and cloud APIs are reachable?	Manifest, scripts, tool schemas, permission diff
Credentials	Which secrets are requested and how are they passed?	Secret broker policy, short-lived role, redacted test log
Network	Where can it connect and what data can leave?	Destination allowlist, DNS/HTTP logs, egress policy
Isolation	What prevents host or cross-project access?	Non-root sandbox, read-only mounts, workspace boundary
Approval	Who approves install, update and consequential actions?	Change ticket, canonical action preview, expiry
Operations	How is it monitored, disabled, rolled back and offboarded?	Inventory, alerts, rollback test, identity revocation

Safe review exercise

1. Do not install the package.
2. Identify every claim that requires independent evidence.
3. Flag the request for cloud-admin credentials as excessive and replace it with a narrowly scoped, short-lived read-only role for assessment.
4. Define the minimum test sandbox and outbound allowlist.
5. Decide whether auto-remediation is ever permitted. Separate reversible tagging from changes to identity, firewall, encryption, retention and deletion.
6. Write the condition that blocks autonomous installation: an agent may recommend a component, but a human change owner must verify and approve the exact pinned artefact.
7. Define re-review triggers: publisher, version, dependency tree, permissions, tool schema, network destinations or ownership changes.

Decision record

- Decision: approve / approve with conditions / reject.
- Exact version or commit:
- Permitted capabilities:
- Prohibited capabilities:
- Approver and expiry:
- Monitoring owner:
- Rollback and revocation evidence:

Security Checklist

Activity 4 - Autonomous Agent Containment Checklist

- ☐ Evaluation targets are synthetic or explicitly authorised and isolated from public infrastructure.
- ☐ Internet access is denied by default and verified from inside the sandbox.
- ☐ Agent, evaluator and target identities are distinct, short-lived and least-privileged.
- ☐ Skills, plugins, MCP servers, tools and dependencies are pinned and allowlisted.
- ☐ The agent cannot discover, install or update capabilities autonomously.
- ☐ Filesystem mounts are minimal and read-only unless the test requires a bounded write path.
- ☐ Outbound network destinations, protocols, data volume and DNS are controlled and logged.
- ☐ Destructive, publishing, identity, credential and cross-boundary actions require human approval.
- ☐ Approval binds the exact command, parameters, target and time window.
- ☐ Rate, cost, step and time budgets stop runaway loops.
- ☐ Behavioural monitoring detects sequences across accounts, repositories and tools.
- ☐ A tested kill switch stops execution and revokes credentials without relying on the agent.
- ☐ Checkpoints support rollback; evidence preserves prompts, plans, tool calls and effects.
- ☐ The incident plan covers third-party notification, legal/privacy assessment and safe disclosure.